



Web Application Security

Part 7

Updated Aug 20, 2026

Presented at SNU Chennai

Sivasubramanian Natarajan

Recommended Text books

- Web Application Security, Andrew Hoffman (O'Reilly)
- Grokking Web application security, Malcom Macdonald (Manning Books)

Recap

Previous class Summary

- XSS
- CSRF
- SQL Injection
- Contemporary web applications (SPA, Reactjs etc., Nodejs)
- High level approach to understanding web application security

Approach to Web application security

Introduction

Broad areas of Web application security

- Minimum security features
- Software Development Lifecycle
- Secure coding practices
- Testing

Minimum Security features

- User management (Authentication, Authorization, Access Control)
- User Input management
- Data Security
- Attacks and Errors prevention
- Application infrastructure security

Software Development Lifecycle

SDLC Perspective

- Design, Coding, Testing and release stages
- The stages are sequential
- Every coding project contains bugs, a percentage of which has the potential to get converted into a vulnerability
- Bugs when caught early in the development stage is less painful to fix, compared with catching them during testing or in the release phase.

Secure coding practices

`https://cheatsheetseries.owasp.org/index.html`

- Authentication, Authorization, Session management
- JWT, OAUTH2 and SAML
- IDE plugins
- Zero trust

Testing for errors and vulnerabilities

<https://owasp.org/www-project-web-security-testing-guide/stable/>

- SAST and DAST
- Vulnerability penetration testing
- Prioritization and fixes
- Regression